

Treatment plan, residual risk (D7) and strategy note

The register is filled in, the residuals are rated, the tool no longer flags any inconsistency. What remains is the work the tool does not do: turning a register into a presentable decision. An executive committee, the COMEX, does not read a register, it reads a plan, and the difference between the two is the whole subject of this final sequence. By the end, the D7 file will be assembled, with the version of the strategy note that carries risk treatment.

Session objectives

By the end of this lab:

- **Assemble** the D7 file with its four acceptance requirements, and check each one before submitting
- **Draft** a treatment decision readable by a third party in two years, without its author to explain it
- **Formalize** an acceptance, including a derogatory one, with the five elements that make it defensible
- **Present** a treatment plan to management, separating what is decided from what is executed
- **Enrich** the strategy note with its treatment subsection, without rewriting the previous ones

Prerequisites

- The risk register completed in the previous lab, with ratings, options, owners, deadlines and residuals.
- The scale and appetite from session 5, and the acceptance line discussed this morning in the tutorial.
- The strategy note in its session 6 state.

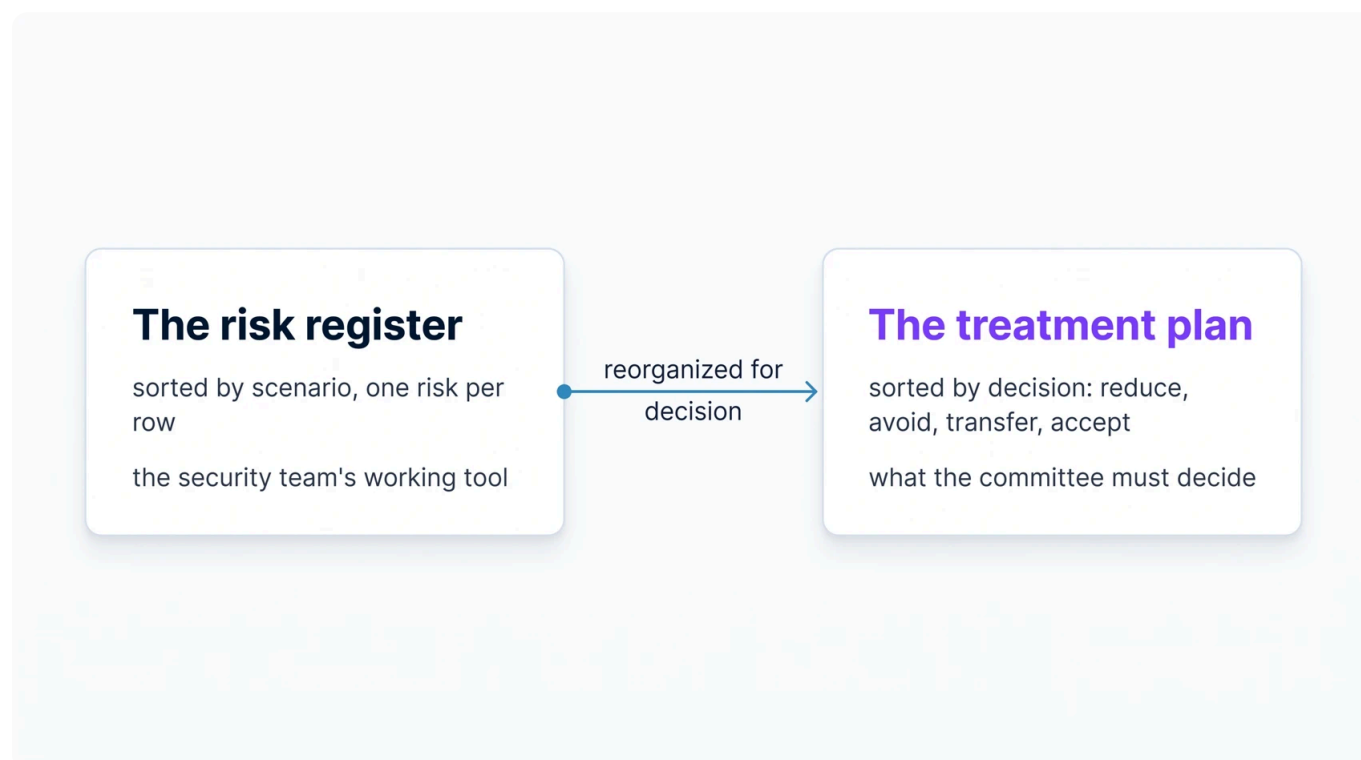
What the D7 file must contain, and how it will be read

The session's deliverable carries four acceptance requirements, and they will be checked one by one. **No risk in the register without a decision. Every residual exceeding the appetite set in session 5 carries a justified derogation. The ratings are consistent with the D5 scales, never recreated.** And each risk carries its option, its measures, its owner, its deadline and its rated residual.

These four requirements are not administrative formalities; each closes a door practice leaves open. The first closes the door of the orphan risk, the one that was identified, rated, then left without follow-up because the meeting ended. The second closes that of implicit acceptance, where an unacceptable residual ends up carried by no one. The third closes that of opportunistic rating, which changes scales when the result displeases.

A remark on reading. The file will be read twice: by a grader after the session, and by its author in session 10 when a committee member asks for a line to be justified. Write for the second reading.

✓ Step 1: building the treatment plan (25 minutes)



Instructions

Extract the register and reorganize it into a treatment plan, by decision and not by scenario, what is reduced, what is avoided, what is transferred, what is accepted: a committee arbitrates decisions, not scenarios. Each reduction line is complete, targeted risk, measure, named owner, deadline, estimated effort and expected effect on the rating, which justifies the residual. Measures that treat several risks at once are grouped: they are the best ones. Visibly separate what belongs to a management decision, committing a budget, giving up an activity, accepting a risk, from what belongs to execution. Effort is entered in the tool, on each applied control, "Cost" section: for the build, the "Fixed cost" in euros and the "People days required for implementation"; for the run, the annual "Fixed cost" and the "People days required annually"; then the "Amortization period (years)" of the build. Where the pack gives nothing, a fixed cost of zero and estimated person-days are enough, provided it is said. The tool converts the days at the instance's daily rate, 500 euros by default in "Settings", "General" tab, "Financial settings" section, to be left as it is today, and computes the annual cost of each control: build divided by the amortization period, plus run. The plan reports for each measure its person-days and its annual cost, distinguishing the build, a capital

expenditure (CAPEX), from the run, an operational expenditure (OPEX); the "Plan d'action" tab of the assessment gives the total in its budget overview. That total is set against the cost-of-inaction range of the morning; this is the trade-off promised to the CFO, a certain cost against a plausible loss. The optional lab of session 11 will go further, outflow, expected loss, return on investment.

To produce: the group's treatment plan on the template below, prioritized over three years, each measure with its person-days and its annual cost read in the tool, build and run distinguished, and its expected effect, management decisions distinguished from execution, and the total annual cost of the plan, read in the budget overview, set against the cost-of-inaction range of the morning.

Decision and targeted risk	Measure	Owner and deadline	Cost (build, run, amortization, annual)	Effect on the rating
Reduce (TRAMONTANE example) : CA1, ransom through the warehouse software vendor	Individual accounts and multi-factor authentication on remote maintenance	Security officer, with the IT department ; 22/09/2026 (year 1)	Build 8,000 € + 10 pd; run 3,000 € + 4 pd per year; 3 years; 9,333 € per year	V3 to V1; Élevé to Moyen

Reading the table: the risk reference is the register's; the deadline is given as year 1 to 3; in the cost column, pd = person-days; build, what is paid once; run, what is paid every year; the duration is the build's amortization period; the annual cost is the one the tool computes at the instance's daily rate.

The readable line test

Take a line of the plan at random and have it read by someone who did not follow the study. If they cannot say who decided what, why and until when, the line needs rewriting. A decision that needs its author to be understood will not survive its author.

Step 2: formalizing the acceptances (20 minutes)

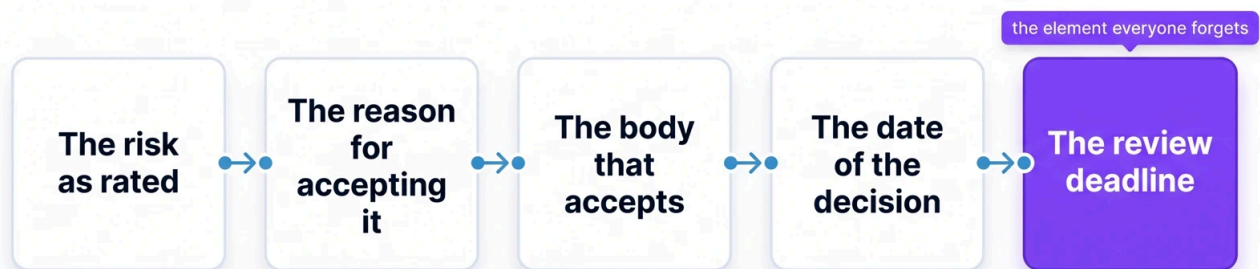
Instructions

Write a decision for each risk accepted as it stands and for each residual that stays above the acceptance line after treatment; both call for a written document, not the same one. The simple acceptance holds in five elements: the risk as rated, the reason for accepting it, the body that accepts, the date and the re-examination deadline. The

derogation adds what a weightier decision requires: why the additional treatment is not undertaken, what would be needed to undertake it, under what condition the derogation would lapse. Check the body: an acceptance is signed at the level where the appetite was set, a derogation at that level or above, never by a subsidiary director on a group-level risk.

To produce: one acceptance sheet per accepted risk and one derogation request per residual above the line, each with its signing body and its re-examination deadline; if there is no derogation to request, write it and say why.

An acceptance in due form



The sentence never to write

"Risk accepted by the CISO." It appears in many real files and it is the exact symptom session 1 taught how to spot: the CISO prepares and proposes, management accepts. A CISO who signs the acceptance carries alone, on the day of the incident, a decision they had no standing to make.

Step 3: the strategy note subsection (15 minutes)

Instructions

Add to the strategy note its risk treatment subsection, without rewriting the previous ones. The note remains a single document of three to five pages of text, tables and appendices not counted, whose session N version contains all the subsections from 1 to N; nothing is deleted, anything can be amended with the sentence that justifies the amendment. Three things suffice in the subsection: the group's position on risk acceptability, the structuring decisions made today, and what remains open with the deadline by which it will be settled. Reread the earlier subsections: if the session 5 appetite does not withstand what has just been rated, amend it and say why.

To produce: the session 7 version of the strategy note, with its new subsection and, where applicable, the justified amendments of the previous ones.

What the length constraint teaches

A CISO who cannot fit within a few pages will not be read. This is not an injustice done to serious people, it is the working condition of the trade: a committee's attention span is short, and security competes with everything else. The work of reduction the note imposes is the same as that of session 10, where speaking time will be ten minutes.

✓ D7 self-assessment grid

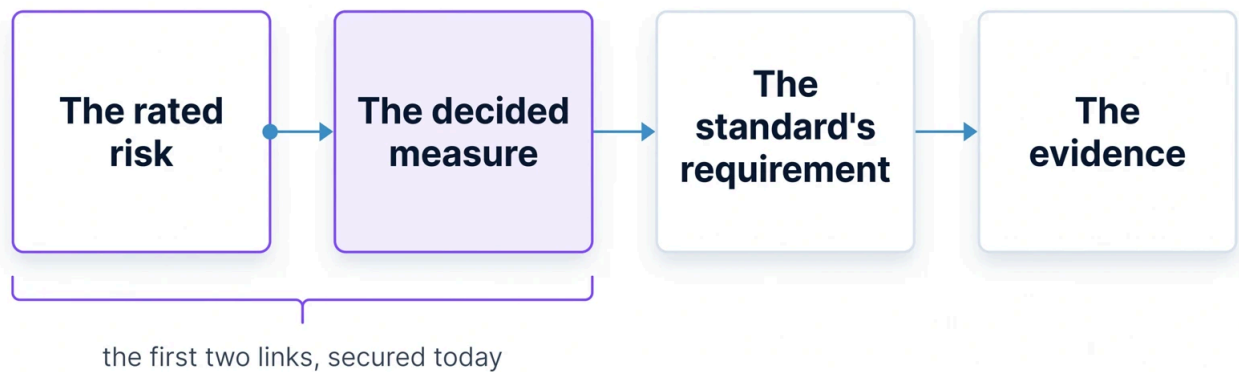
Requirement	Achieved when	Sign that it is not achieved
No risk without a decision	Each line of the register carries an option, or the written explanation of its postponement with the name of who will decide	Scenarios left in the open state
Justified derogations	Each residual above the appetite carries its justification and its body	A high residual with no particular mention
Consistent ratings	The levels cited are those of D5, without exception	A new scale appearing midway through the file
Traceability of measures	Targeted risk, measure, owner, deadline, expected effect	A measure without an owner or a deadline
Effort and annual cost	Each measure carries its person-days and its annual cost read in the tool, build and run distinguished; the plan carries its total against the cost of inaction	Measures with no cost, impossible to prioritize or to arbitrate
Consistent residuals	Rated after the decision, never higher than the current level	A residual entered before the measures
Legitimacy of signatures	Acceptances and derogations at the level where the appetite was set	"Risk accepted by the CISO"
Readability	Each line is understood without its author	Decisions that call for an oral explanation

✓ What carries over to session 8

The D7 file is the direct material of the next session, and it is the most important junction of the course. In the next session, the Statement of Applicability (SoA) justifies the inclusion of each measure of the reference framework by a D7 risk or by a legal or contractual requirement. In other words, what has just been decided becomes the proof that the management system rests on an analysis and not on a copied list.

So check one thing before submitting: that each measure of the treatment plan is phrased so that it can be matched to a requirement of the reference framework chosen in session 3. A measure written in overly general terms, "strengthen access security", matches nothing. The same measure written in terms of an objective, "remove shared administration accounts in favor of traced individual accounts", attaches directly and can be verified.

That thread is what makes a certification defensible: from the rated risk to the decided measure, from the decided measure to the framework requirement, and from the requirement to the evidence. The first two links of it are secured today.



Answer key for the teacher: D7 run on
TRAMONTANE (GØ instance)

– cliquer pour
révéler